Parul® University
Vadodara, Gujarat

NAAC GRADE A++

Systems Vulnerability Scanning

Mr. Arpan Bora
Department of CSE (Cyber Security)
PIET, Parul University

Basic Fundamental Concept

IP Address

- An Internet Protocol address (IP address) is a numerical label assigned to each device (e.g., computer, printer) participating in a computer network that uses the Internet Protocol for communication.
- An IP address serves two principal functions: host or network interface identification and location addressing.

Two Version of IP address:-

IPv4	•IPv4 uses 32-bit for address •. Example: 192.168.1.1
IPv6	•IPv6 uses 128-bit for address. •Example: 2001:0db8:85a3:0000:0000:8a2e:0370:7334

- IP addresses are usually written and displayed in human-readable notations.

Cont…

MAC Address

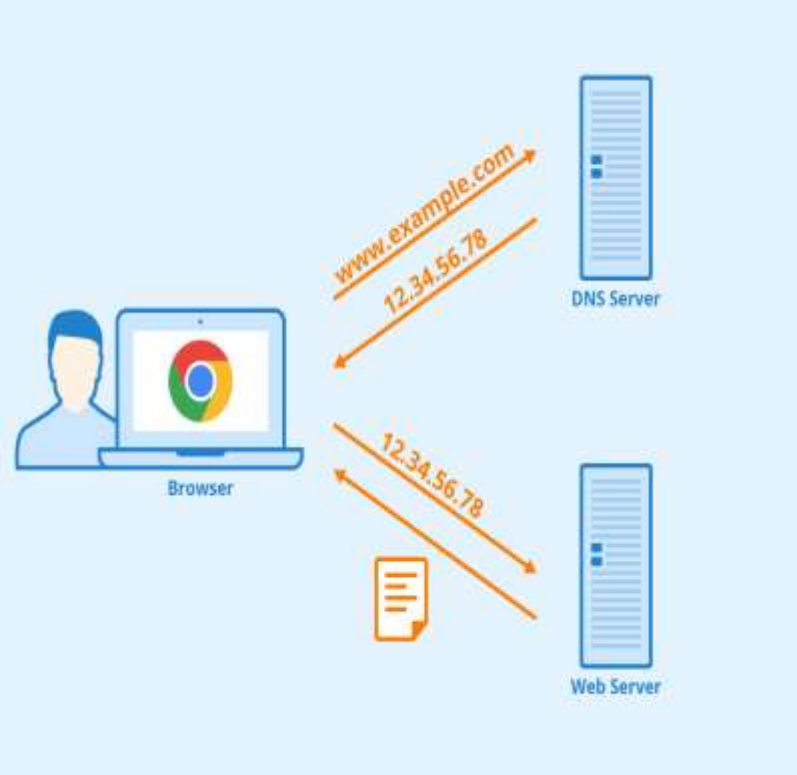
- A media access control address (MAC address) is a unique identifier assigned to network interfaces for communications on the physical network segment.
- MAC addresses are used as a network address for most IEEE 802 network technologies, including Ethernet, Wi-Fi & Bluetooth.
- It is also known as physical address or hardware address.
- The MAC address is a string of usually six sets of two-digits or characters, separated by colons.
- For example,consider a network adapter with the MAC address 01:0a:95:9d:58:36.

Cont…

- **DNS** stand for “domain name system”.
- It converting human-readable website name into computer-readable numerical IP addresses.

For example:

- If you want to visit Google, then open www.google.com into your web browser‘s address bar instead of IP address. However, your computer does not understand where www.google.com is located.
- Behind the scenes, the internet and other network use numerical IP addresses. www.google.com is located at the IP address 73.194.39.78 on the internet.

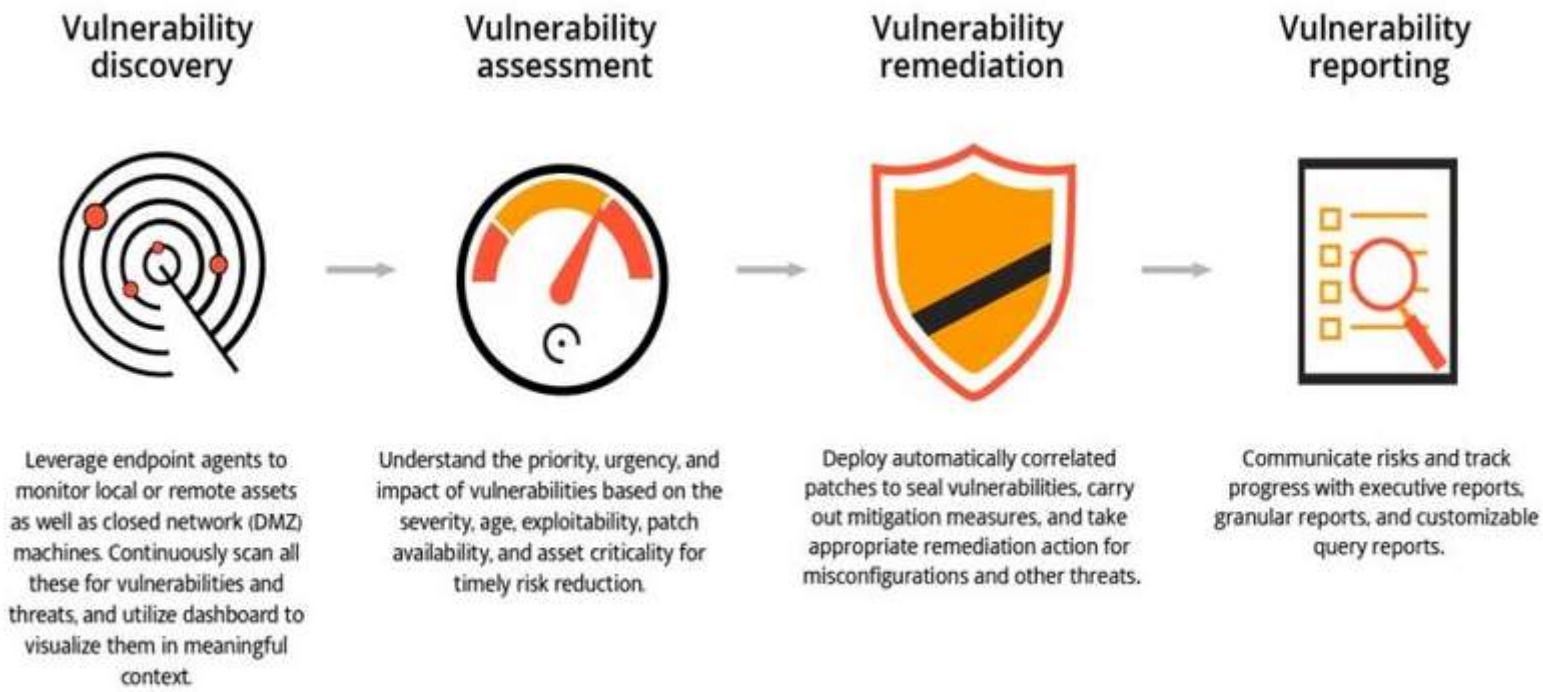


Overview of Vulnerability Scanning

Vulnerability

- Vulnerability is a weakness which allows an attacker to reduce a system's security.
- Vulnerability scanning usually refers to the scanning of systems that are connected to the Internet.
- It can also refer to system scanning or audits on internal networks that are not connected to the Internet in order to assess the threat of malicious software.
- It is possible to know the basic security measures when installing and managing network and websites. but it is not possible to catch all the vulnerabilities reside in the network and websites.

Cont...


Vulnerability discovery
Vulnerability assessment
Vulnerability remediation
Vulnerability reporting
Leverage endpoint agents to monitor local or remote assets as well as closed network (DMZ) machines. Continuously scan all these for vulnerabilities and threats, and utilize dashboard to visualize them in meaningful context.
Understand the priority, urgency, and impact of vulnerabilities based on the severity, age, exploitability, patch availability, and asset criticality for timely risk reduction.
Deploy automatically correlated patches to seal vulnerabilities, carry out mitigation measures, and take appropriate remediation action for misconfigurations and other threats.
Communicate risks and track progress with executive reports, granular reports, and customizable query reports.

Classifications Of Vulnerability

Vulnerability originates from three sources:

- Vendor-originated: This includes software bugs, missing operating system patches, vulnerable services, insecure default configurations, and web application vulnerabilities.

- System administration-originated: This includes incorrect or unauthorized system configuration changes, lack of password protection policies, and so on.

- User-originated:This includes sharing directories to unauthorized parties, failure to run virus scanning software, and malicious activities, such as deliberately introducing system backdoors.

Types Of Vulnerability Scanners

There are generally two types of vulnerability scanning tools:

1. **Network-based scanning tool:**

Network-based scanning tools send network traffic to various network hosts and devices.

It with the goal of gathering information that will indicate whether those systems have holes that can be exploited.

Example: OpenVAS, Wireshark, NMAP, Nikto etc.

2. **Host-based scanning tool:**

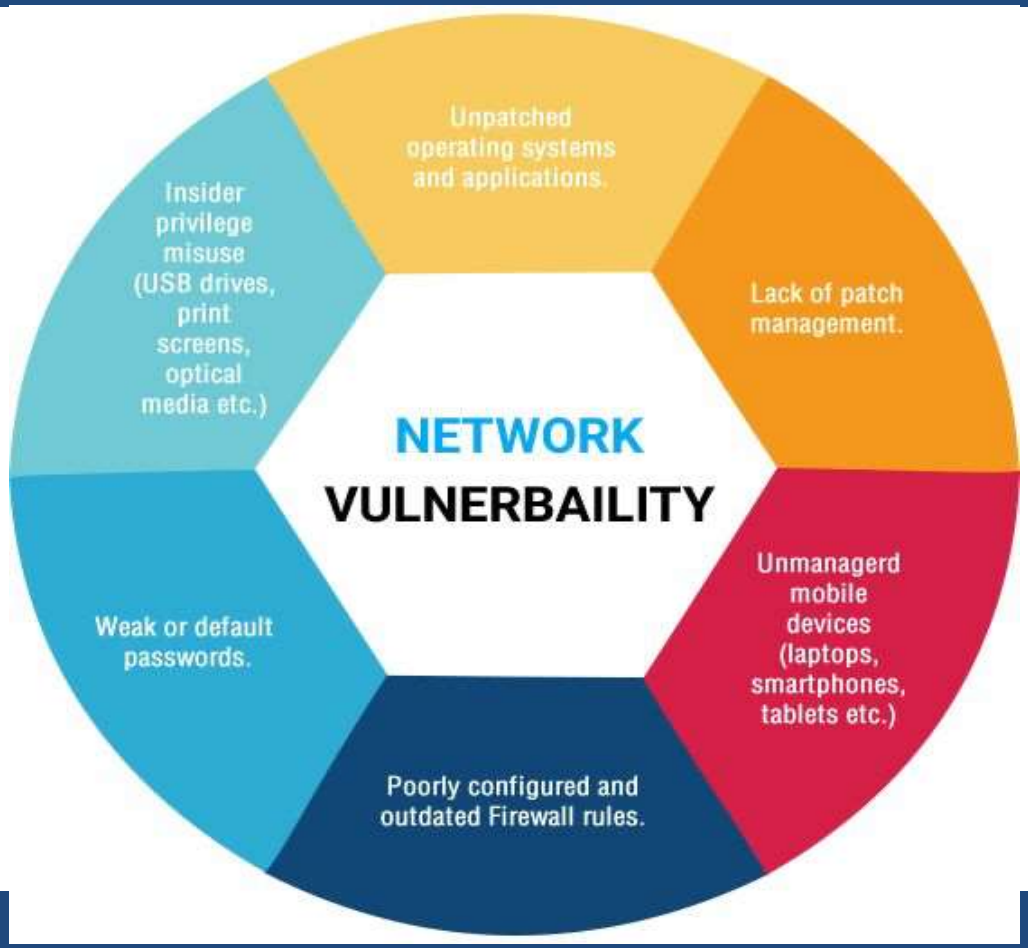
Host-based scanning tools are run on each host to scan for a wide range of system problems.

It including unauthorized software, unauthorized accounts, unprotected logins, weak passwords and inappropriate access permissions.

Example: OSSEC

Cont…

- The vulnerability scanners provide you the automate security auditing and play an important role in your IT security.
- The vulnerability scanners can scan your network and websites for up to thousands of different security risks.
- It produces a list of those vulnerabilities, and gives steps on how to overcome or reduce them.



Cont…

Cloud-Based Vulnerability Scanners

- Used to find vulnerabilities within cloud-based systems such as web applications, WordPress, and Joomla.

Host-Based Vulnerability Scanners

- Used to find vulnerabilities on a single host or system such as an individual computer or a network device like a switch or core-router.

Network-Based Vulnerability Scanners

- Used to find vulnerabilities in an internal network by scanning for open ports. Services running on open ports determined whether vulnerabilities exist or not with the help of the tool.

Database-Based Vulnerability Scanners

- Used to find vulnerabilities in database management systems. Databases are the backbone of any system storing sensitive information. Vulnerability scanning is performed on database systems to prevent attacks like SQL Injection.

False Negative

- The vulnerability scanners use predefined tests to identify vulnerabilities (also called vulns).
- If the scanner has insufficient test then the scanner does not report the vulnerability exists on the system.
- It can be known as false negative.

False Positive

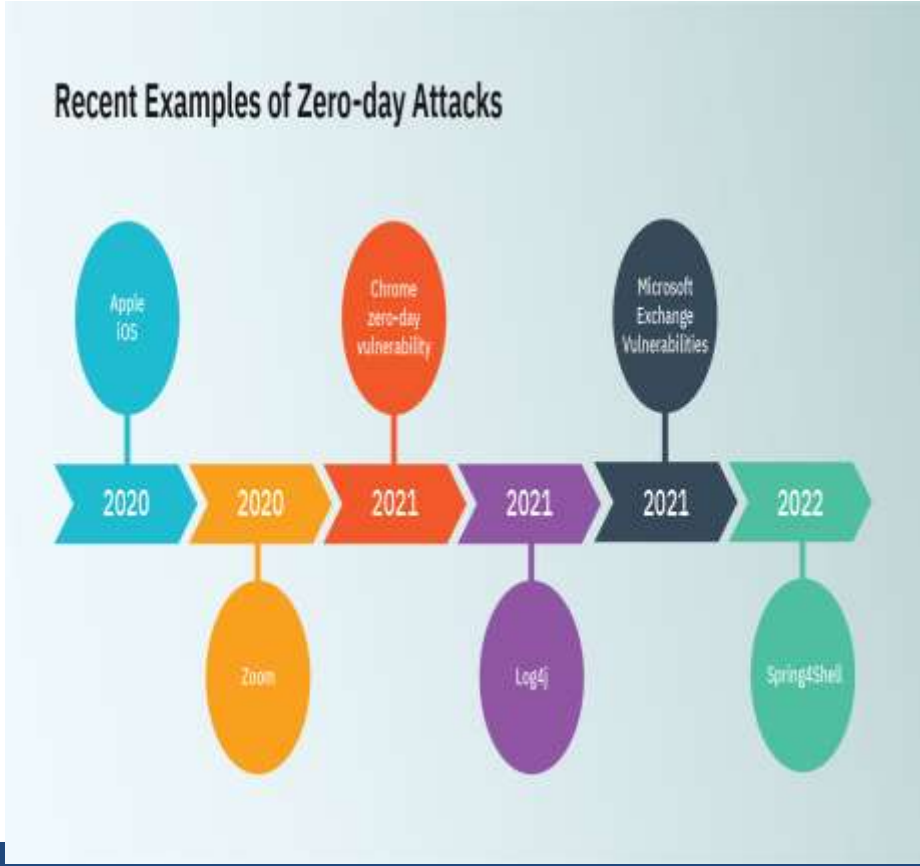
- If the scanner has a poorly written test then scanner reports vulnerability even if it does not exist on a system. It may produce a false positive.
- It wastes time as administrators must follow up to manually check the vulnerability that is actually vulnerable or not.

Some of the free and very useful vulnerability scanners are:

- Netcat
- Socat

Zero-day Vulnerability

- Zero-day vulnerability refers to a hole in software that is unknown to the vendor.
- This security hole is then exploited by hackers before the vendor becomes aware and hurries to fix it- this exploit is called a zero day attack.
- Zero-day vulnerabilities are particular dangerous because they represent a gap in knowledge between the attacker and defender.



Common Vulnerabilities

SQL Injection (SQLi):

- Description: SQL injection is a code injection technique where an attacker can insert malicious SQL statements into a query, potentially gaining unauthorized access to a database.
- Prevention: Use parameterized queries or prepared statements, input validation, and least privilege principles.

Cross-Site Scripting (XSS):

- Description: XSS involves injecting malicious scripts into web pages that are viewed by other users. It can lead to the theft of sensitive information or session hijacking.
- Prevention: Input validation, output encoding, and implementing secure coding practices.

Cont...

Cross-Site Request Forgery (CSRF):

- Description: CSRF is an attack where a malicious website causes a user's web browser to perform an unwanted action on a trusted site where the user is authenticated.
- Prevention: Use anti-CSRF tokens, implement the Same Site attribute for cookies, and ensure proper authentication.

Buffer Overflow:

- Description: Buffer overflow occurs when a program writes more data to a block of memory, or buffer, than it was allocated for, leading to potential code execution by an attacker.
- Prevention: Bounds checking, input validation, and using secure coding practices.

Cont...

Security Misconfigurations:

- Description: Improperly configured settings, permissions, or default configurations can expose sensitive information or provide unauthorized access.
- Prevention: Regularly audit configurations, follow security best practices, and minimize unnecessary services.

Insecure Direct Object References (IDOR):

- Description: IDOR occurs when an application provides direct access to objects based on user-supplied input, allowing unauthorized access to data.
- Prevention: Implement proper access controls, validate user input, and use indirect references rather than direct references.

Open Port/Service Identification

- Some services are very insecure. Telnet (port 23) is famous for its lack of encryption that leaks passwords.
- Hence Secure Shell (SSH) is widely accepted and reduced the presence of telnet on the Internet.
- Services do not always run on default ports, hence the scanner must rely on banners and “nudges” to produce a response from a listening port.
- Services do not always declare themselves. Telnet and SMTP (port 25) services return text-based banners when receives request for connection. It does not wait for particular incoming data on that connection.
- HTTP (port 80) will not respond for connection until the service receives a request that contains data.
- This way, scanners may distinguish whether an HTTP or SMTP service is listening on non-standard port.

Banner/ Version Check

- Some services declare information about themselves without receiving particular data from a client.

Banner Grabbing:

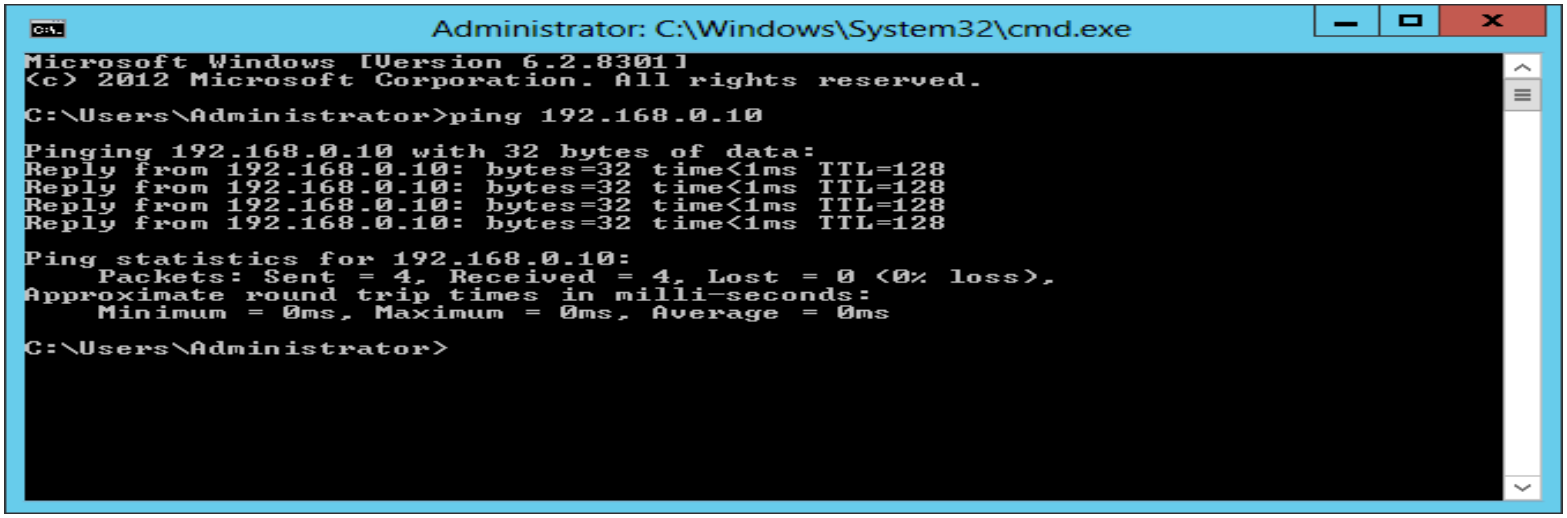
- Banner grabbing is a technique used to gain information about a computer system on a network and the services running on its open ports.
- Administrators can use this to take inventory of the systems and services on their network.
- Tools commonly used to perform banner grabbing are Telnet, nmap, zmap and Netcat.

Example:

- SSH command
- If you know the version of SSH and target operating system then it is very easy for someone to compromise the host.
- System administrators usually remove or change banners to make them more secure, but this doesn't remove the vulnerability.

Probe

- In Computer Security, a probe is an attempt to gain access to a computer and its files through a known or probable weak point in the computer system.
- A probe is an action taken or an object used for the purpose of learning or collecting data about the state of the network.
- For example, an empty message can be sent simply to see whether the destination actually exists. Ping is a common utility for sending such a probe.



Two Type of Probe

- Traffic Probe
- Vulnerability Probe

Traffic Probe

- Some services declare information about themselves without receiving particular data from a client.
- But all services do not do that. However, lots of them will if you just ask.
- For example, a web service will not give response until it receives data from the client.
- A valid HTTP request using the HEAD method will provide some useful information like web server information, information about installed server operating system etc. which can be useful to compromise the host.
- Traffic probes try to use valid requests. Because valid protocol messages are less likely to crash or interrupt a service
- If a web server didn't handle the HEAD method without crashing then the chances of compromising increases. So this type of buggy service must need to be fixed to lower the chances of compromising.

Vulnerability Probe

- Some security bugs cannot be identified without sending a payload that exploits (using something to one's own advantage) a suspected vulnerability.
- These types of probes are more accurate—they rely on direct observation not only on port numbers or service banners.
- But they also carry more risk of interrupting the service, because the test payload must be trying to either produce or take advantage of an error in the service's code.
- An easy-to-understand example of a vulnerability probe is an HTML injection check for a web application.
- A snippet of HTML might look like Results for 'zombies'...
- An attacker who exploits HTML injection vulnerability like this could steal data from the user or damage the web site.

Cont…

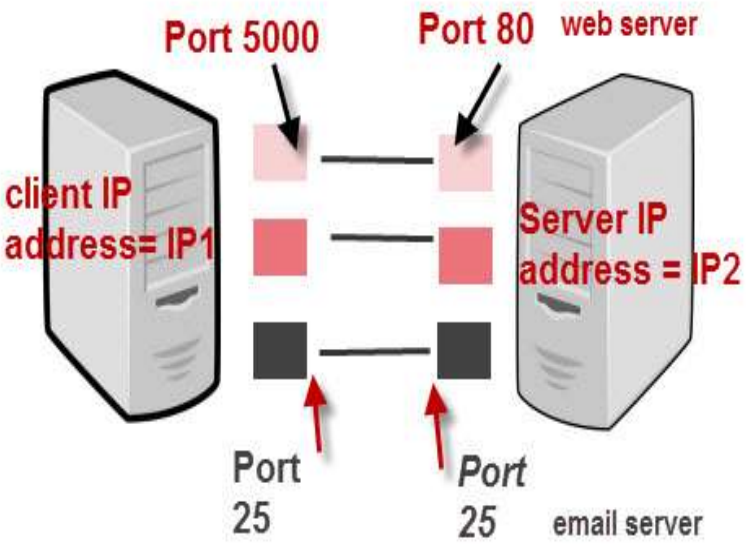
- The hacker can take advantage of vulnerability to compromise the system or network.
- The outcome may be to crash the software, causing a denial of service, or retrieve data, like pulling usernames and passwords from a database, or completely compromise the operating system by gaining root or administrator access.
- Exploits take many shapes. It can be simple binary shellcode or clever bits of text appended to URL parameters.
- Discovering vulnerability typically just means uncovering a software fault.
- Developing an exploit means taking advantage of that software fault to give the attacker an advantage against the system.

TCP/IP Ports and Sockets

- On a TCP/IP network every device must have an IP address.
- The **IP address identifies** the **device** e.g. computer.
- However an IP address alone is **not sufficient for running network applications**, as a computer can run multiple applications and/or services.
- Just as the IP address identifies the computer, The **network port identifies** the **application** or **service** running on the computer.
- The diagram below shows a computer to computer connection and identifies the IP addresses and ports.

Cont…

- A **socket** is the **combination** of **IP address** + **port**
- A **connection between** two **computers uses** a **socket**.



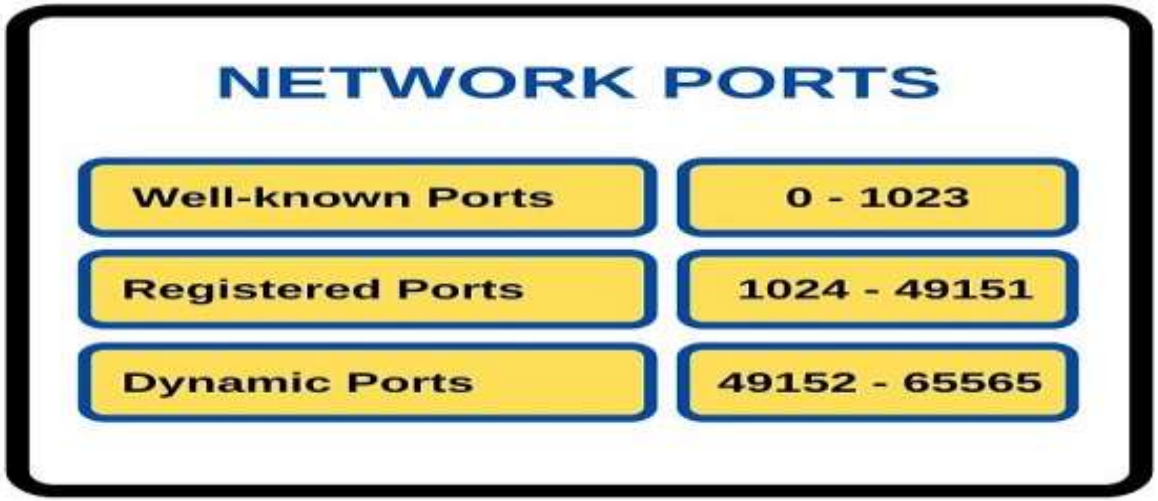
IP Address + Port number = Socket

TCP/IP Ports And Sockets

Port Number Ranges and Well Known Ports

- A port number uses **16 bits** and so can therefore have a value from **0 to 65535 decimal.**

Port numbers are divided into ranges as follows:



Cont…

- **Port numbers 0-1023 – Well known ports.**
- These are allocated to server services by the **Internet Assigned Numbers Authority** (**IANA**).
- e.g **Web servers** normally use **port 80** and **SMTP servers** use **port 25**.
- **Ports 1024-49151- Registered Port**
- These can be registered for services with the IANA and should be treated as **semi-reserved**.
- **User written programs should not use these** ports.
- **Ports 49152-65535 - Dynamic Port**
- These are **used by client programs** and you are **free to use** these in client programs.
- When a Web browser connects to a web server the browser will allocate itself a port in this range.
- Also known as **ephemeral ports**.

Number	Assignment
20	File Transfer Protocol (FTP) Data Transfer
21	File Transfer Protocol (FTP) Command Control
22	Secure Shell (SSH) Secure Login
23	Telnet remote login service, unencrypted text messages
25	Simple Mail Transfer Protocol (SMTP) E-mail routing
53	Domain Name System (DNS) service
67, 68	Dynamic Host Configuration Protocol (DHCP)
80	Hypertext Transfer Protocol (HTTP) used in the World Wide Web
110	Post Office Protocol (POP3)
119	Network News Transfer Protocol (NNTP)
123	Network Time Protocol (NTP)
143	Internet Message Access Protocol (IMAP) Management of digital mail
161	Simple Network Management Protocol (SNMP)
194	Internet Relay Chat (IRC)
443	HTTP Secure (HTTPS) HTTP over TLS/SSL

Port Scanning

Port scanner:

- Software designed to probe server or host for Open ports.
- Used by administrator to verify security policy.
- Used by attacker to identify running services on host.

Port scan:

- A process that sends a client request to server for finding active ports.

Open port:

- Host sends a reply indicating port is active.

Close port:

- Host sends a reply that connection will be denied.

Filtered:

- There was no reply from the host.
- Vulnerability can be with **open ports** or **operating system of running host**.

Vulnerability Scanning vs. Penetration Testing

Basis	Penetration Testing	Vulnerability Assessment
Objective	Its objective is to actively exploit vulnerabilities to assess the effectiveness of the security measures and identify potential entry points an attacker could exploit to breach a system.	It aims to identify and quantify system, network, or application vulnerabilities. It focuses on identifying weaknesses and security flaws that could be exploited by attackers.
Methodology	It combines automated and manual techniques. It may start with a vulnerability assessment to identify potential weaknesses but then progresses to actively exploiting vulnerabilities through various attack scenarios using ethical hacking techniques.	It often uses automated tools and techniques to scan and analyze systems for known vulnerabilities, misconfigurations, and weak security controls.

Cont...

Analysis	It involves a deeper dive into vulnerabilities. It attempts to exploit identified vulnerabilities and gain access to sensitive information, escalate privileges, or compromise the system to assess the potential impact of an attack.	It provides a broad view of potential vulnerabilities, often with a prioritized list of vulnerabilities based on severity. It does not typically attempt to exploit vulnerabilities or verify their impact.
Output	The output of penetration testing is a detailed report that includes the vulnerabilities discovered, the exploited attack vectors, the impact of successful attacks, and recommendations for improving security.	The output of a vulnerability assessment is usually a report that lists the identified vulnerabilities, including their severity ratings and recommendations for remediation.
Frequency	It is typically conducted periodically, such as annually, or after significant changes to systems or applications. It is a more resource-intensive process and is often used to validate the effectiveness of security measures after vulnerability assessments.	It can be performed regularly, even on a continuous basis, as part of ongoing security monitoring. It helps organizations identify new vulnerabilities as software and systems are updated or changed.

Network Vulnerability Scanning - Netcat

- The Netcat performs function with a broad application to hacking and network debugging: It reads and writes data for TCP and UDP connections.
- Netcat enables you to redirect shell commands across a network
- Netcat interacts directly with a TCP or UDP service.
- You can inspect the raw data sent by a service, manually interact with the service, or redirect network connections with stdin, stdout.
- You can connect to text-based protocols like SMTP and HTTP, UDP services like DNS, and even binary protocols.
- Netcat is often called the “Swiss Army knife” of hacking.

Uses of Netcat

Hackers have come up with hundreds of ways to use Netcat. Some of the uses of Netcat are given here in detail:

- Obtain Remote Access to a Shell
- Perform Basic Port Scanning
- Identify more information about ports
- Communicate with UDP Services
- For IP Spoofing
- Hijack a Service
- Create Proxies and Relays
- Bypass Port Filters

Socat

- Socat is a clone of Netcat with extensive configuration options.
- It supports several protocols, from OpenSSL to proxies to IPv4 and IPv6.
- Socat uses word-based directives on the command line.
- Socat is part of the BSD ports collection and available as a package for most Linux OS.

<u>Socat's command line follows a simple format, as follows:</u>

- $ socat options address1 address2
- The options resemble common "dash letter" flags such as -d, -h, and -v.
- A basic address specification consists of a keyword, followed by a list of parameters and behaviour options.

Cont…

- Address specifications are not case sensitive, but we will define them in uppercase to help distinguish them on the command line.
- For example, the following command connects stdio (the first address) to TCP port 80 on a remote host (the second address):
- $ socat STDIO TCP:deadliestwebattacks.com:80
- Since the first address is stdio, you can pipe data into the command just as you would with nc or any other shell command. Traffic is forwarded between the two addresses.
- Hence, the data piped into stdio is forwarded to the TCP host, whose response makes the round trip back through stdio.

Datapipe

- A port redirection tool passes TCP/IP traffic received by the tool on one port to another port to which the tool points.
- A port redirection tool functions as a channel for TCP/IP connections.
- For example, you could place a datapipe on a system between a browser and a web server.
- If you pointed the browser to the listening port of the system with the redirection tool, the browser would see the contents of the web server without having to directly access the web server's IP address.
- Datapipe is a Unix-based port redirection tool. It runs on the UNIX OS.
- $ ./datapipe
- ./datapipe localhost localport remotehost remoteport

Cont…

- The localhost argument indicates the IP address on which to open the listening port.
- It may be the localhost interface (i.e., 127.0.0.1) or the address of a network interface on the
- local system from which the datapipe command is being executed.
- The localport argument indicates the listening port on the local system; connections will be maAde to this port number.
- On UNIX systems, you must have root privileges to open a listening port below 1024.

Cont…

- If you receive an error similar to “bind: Permission denied,” your account may not have privileges to open a reserved port.
- The remoteport argument indicates the port to which data is to be forwarded.
- For example, in most cases if the target is a web server, the remoteport value will be 80.
- The remotehost argument indicates the hostname or IP address of the target.
- The easiest conceptual example of port redirection is forwarding HTTP traffic.

Cont…

Here we set up a datapipe to listen on a high port, 9080 in this example, that redirects to a web site of our choice:

- $ ./datapipe my.host 9080 80 www.google.com

Now, we enter this URL into a web browser:

- http://my.host:9080/

- You should see Google's home page.
- Datapipe performs a basic function, but with a little creativity you can make it a powerful tool.
- Port redirection forwards traffic between TCP ports only.
- It does not perform protocol conversion or any other data manipulation.
- Redirecting web traffic from port 80 to port 443 will not change HTTP connections to encrypted HTTPS connections.
- Use an SSL proxy instead, such as Stunnel.

FPipe

- It implement port redirection techniques natively in windows. It adds UDP protocol and outbound source port number support, which does not in datapipe.
- FPipe is a TCP source port forwarder/redirector. It can create a TCP / UDP stream with a sourse port of your choice. This is useful for getting past firwalls that allow traffic with source ports of 23, to connect with internal servers.
- Fpipe runs on windows operating system. There is no need of priviledge user account and support from dynamic link library.
- Fpipe can run on local host of the application that you are trying to use to get inside firewall.

Cont…

- When you start Fpipe, it will wait for a client to connect on its listening port.
- It makes a listening connection is made a new connection to the destination machine and port with the specified local source port will be made.
- When the full connection has been established, Fpipe forwards all the data received on its inbound connection to the remote destination port beyond the firewall.

Fpipe Option

Sr No.	Option	Description
1	-? Or -h	Display Help
2	-c	Max. allows simultaneous TCP connections. Default 32 connections are allowed.
3	-i	Listening interface IP address
4	-l	Listening port number
5	-r	Remote port number
6	-s	Source port used for outbound traffic
7	-u	It support UDP mode
8	-v	For verbose mode

Winrelay

- Winrelay is windows based port redirection tool. It uses static source port for redirected traffic.
- Some antivirus software consider as malicious software.
- Online games use datapipe and fpipe tools. Port redirction tools are useful for assigning the alternative port to a service.

Source:

- www.ntsecurity.nu/toolbox/winrelay/

Network Reconnaissance

- **Reconnaissance** attack is a kind of information gathering on network system and services. This enable the attacker to discover vulnerabilities or weaknesses on the network.
- Reconnaissance attack can be active or passive.

Tools:

- AMAP: Application Mapper, uses the results from Nmap to mine for more information.
- Nessus: It is vulnerability scanner.
- Scanrand: It is fast network scanner.
- Paratrace: TCP traceroute that utilizes selected TTL messages.
- Intruders are increasingly making use of compromised hosts to launch reconnaissance againt target networks.

NMAP

- Nmap ("Network Mapper") is a free and open source (license) utility for network discovery and security auditing.
- Many systems and network administrators also find it useful for tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime.

Nmap uses raw IP packets in novel ways:

  - To determine what hosts are available on the network.
  - Available services (application name and version) those hosts are offering.
  - Operating systems (and OS versions) they are running.
  - Type of packet filters/firewalls are in use.

- It was designed to rapidly scan large networks, but works fine against single hosts.

Cont…

- Nmap runs on all major computer operating systems, and official binary packages are available for Linux, Windows, and Mac OS X.
- In addition to the classic command-line Nmap executable, the Nmap suite includes:
  - An advanced GUI and results viewer (Zenmap).
  - A flexible data transfer, redirection, and debugging tool (Ncat).
  - A utility for comparing scan results (Ndiff).
  - A packet generation and response analysis tool (Nping).
- It was even featured in twelve movies, including The Matrix Reloaded, Die Hard 4, Girl With the Dragon Tattoo, and The Bourne Ultimatum.

NMAP Characteristics and Source

- Flexible
- Powerful
- Portable
- Easy
- Free
- Well Documented
- Supported
- Acclaimed
- Popular

Source:

- http://nmap.org/

THC – Amap (The Hackers Choice Amap)

- Amap was the first next-generation scanning tool for pentesters.
- It attempts to identify applications even if they are running on a different port than normal.
- It also identifies non-ascii based applications.
- This is achieved by sending trigger packets, and looking up the responses in a list of response strings.
- Most of port scanners assume that if a particular port is open, then default application for that port must be present.
- Amap probes these ports to find out what is really running on that port.
- Source:
- https://github.com/vanhauser-thc/THC-Archive/tree/master/Tools
- http://thc.segfault.net/thc-amap/

THC – Amap Modes

Sr. No.	Modes	Remarks
1	-A	It identifies the service associated with the port.
2	-B	This mode does not perform identification.
3	-P	It conducts a port scan.

Network Sniffers and Injection

- A packet sniffer is a wire-tap device that plugs into computer networks and eavesdrops on the network traffic.
- Sniffers are the best tools for hackers to attack computers.
- Network administrators use sniffers for network troubleshooting and security analysis.
- Many sniffing and anti-sniffing packages available on the internet for download.
- Network sniffers tools are used to watch over networks as well as collect all kinds of information including diagnostic information.

Usages of Network Sniffer tools

Sniffing packages used for network traffic analysis to:

1. Identify the type of network application used.
2. Identify the hosts using network.
3. Identify the bottlenecks.
4. Capture data sniffing packages used for troubleshooting of network application.
5. Create network traffic logs.

Wireshark

- Wireshark is a free and open source packet analyzer.
- It is used for network troubleshooting, analysis, software and communication protocol development and education.
- It runs on Linux, UNIX, OSx, BSD, Solaris, and Microsoft windows.

Cont…

It provides following functionality:

- Wireshark is very similar to tcpdump, but has a graphical front-end, plus some integrated sorting and filtering options.
- User can see all traffic visible on that interface.
- If a remote machine captures packets and sends the captured packets to a machine running Wireshark using the TZSP protocol. So it can analyse packets captured on a remote machine at the time they are captured.
- It understands the structure of different networking protocols. It can parse and display the fields along with their meanings as specified by different protocols.
- You can use it to review traffic captured by tools like tcpdump or WinDump or use it to capture traffic directly.
- It also supports capture formats from several other commercial and open source network sniffers.

Ettercap

- Ettercap is a free and open source network security tool for man-in-the-middle attacks on LAN.
- It can be used for computer network protocol analysis and security auditing.
- It runs on various UNIX- like operating systems including Linux, mac os x, BSD and Solaris, and on Microsoft windows.
- It is capable of intercepting traffic on a network segment, capturing passwords and conducting active eavesdropping against a number of common protocols.
- Ettercap works by putting the network interface into promiscuous mode and by ARP poisoning the target machines.
- Thereby it can act as a ‘man in the middle’ and unleash various attacks on the victims.
- Ettercap supports active and passive dissection of many protocols and provides many features for network and host analysis.

Ettercap - Modes of Operation

- Ettercap offers four modes of operation.

These are as follows:

- IP-based: packets are filtered based on IP source and destination.
- MAC-based: packets are filtered based on MAC address, useful for sniffing connections through a gateway.
- ARP-based: uses ARP poisoning to sniff on a switched LAN between two hosts.
- PublicARP-based: uses ARP poisoning to sniff on a switched LAN from a victim host to all other hosts.

Features of Ettercap

- Character injection into an established connection. Characters can be injected into a server or to a client while maintaining a live connection.
- It supports sniffing of a password and username and even the data of an SSH1 connection.
- It supports sniffing of HTTP SSL secured data-even when the connection is made through a proxy.
- It supports in setting up a filter that searches for a particular string in the TCP or UDP payload and replaces it with a custom string or drops the entire packet.
- It can determine the OS of the victim host and its network adapter.
- It can kill connections of choices from the connection-list.
- It can hijack DNS requests.
- It can also find other poisoners on the LAN actively or passively.

Hping

- Hping is a free packet generator and analyzer for the TCP/IP protocol. It is one of the tools for security auditing and testing of firewalls and networks.
- It was used to exploit the idle scan scanning technique and now implemented in the NMAP security scanner.
- The new version of hping, hping3, is scriptable using the tcl language and implements an engine for string based, human readable description of TCP/IP packets, so that the programmer can write scripts related to low level TCP/IP packet manipulation and analysis in very short time.
- Hping also has a listen mode, enabling it to be used as an unsophisticated backdoor for covert remote access or file transfers.
- Hping's "listen" mode can be used for receiving data.
- When hping is in listen mode, it monitors traffic for a special "signature" that indicates it should capture the data to follow.

Use of Hping

- Determining a Host’s Status When Ping Doesn’t Work.
- Testing Firewall Rules.
- Stealth Port Scanning.
- Remote OS Fingerprinting.

Kismet

- Kismet is a free software and it is network detector, packet sniffer and intrusion detection system for 802.11 wireless LANs.
- Kismet will work with any wireless card which supports raw monitoring mode and can sniff 802.11a, 802.11b, 802.11g and 802.11n traffic.
- This runs under Linux, FreeBSD, NetBSD, openBSD, and mac OS X, Microsoft windows.
- **Kismet has three separate parts.**

A drone
- it can be used to collect packets and then pass them on to a server for interpretation.

A server
- it can either be used in conjunction with a drone or on its own, interpreting packet data and extrapolating wireless information and organizing it.

The client
- it communicates with the server and displays the information the server collects.

Features of Kismet

- Kismet differs from other wireless network detector in working passively.
- It is able to detect the presence of both wireless access and wireless client.
- Kismet also includes basic wireless IDS features such as detecting active wireless sniffing programs including NetStumbler, as well as a number of wireless network attacks.
- It has the ability to log all sniffed packets and save them in a tcpdump/wireshark compatible file format.
- Kismet can also capture “per-packet information” headers.
- It has ability to detect default or not configured networks, probe requests, and determine what level of wireless encryption is used on a given access point.

Cont…

- Kismet supports channel hoping.
- This means that it is constantly changes from channel to channel non-sequentially, in a user defined sequence with a default value that leaves big holes between channels.
- The advantage with this method is that it will capture more packets because adjacent channels overlap.
- Kismet also supports logging of the geographical coordinates of the network if the input from a GPS receiver is additionally available.

Parul® University | NAAC GRADE A++

https://paruluniversity.ac.in/